PLANTILLA P58 · PLAN ANUAL DE AUDITORÍA DE IA

Plan anual de auditoría de IA

Construye el universo auditable, prioriza cada unidad por riesgo, asigna los trabajos del ejercicio con su capacidad y deja constancia de la aprobación y del grado de ejecución trimestral.

Fernando García Varela Versión 0.1 (borrador de trabajo) 19-09-2026 Borrador para revisión

EN ESTE DOCUMENTO

01 Instrucciones de uso

02 Identificación

03 Universo auditable

04 Puntuación de prioridad

05 Plan de trabajos del ejercicio

06 Capacidad y recursos

07 Aprobación del plan y limitaciones

08 Seguimiento de la ejecución

09 Criterios de calidad

10 Aprobación y verificación

11 Control de versiones

Aviso legal y exención de responsabilidad. SEVEN-G es un marco metodológico de referencia que se ofrece «tal cual» y con fines exclusivamente informativos. No constituye asesoramiento jurídico, regulatorio, financiero ni profesional, ni garantiza el cumplimiento de ninguna norma. Las referencias a regulación general (como el Reglamento Europeo de IA, el RGPD, DORA o NIS2), a normas técnicas y a regulación específica de cada sector o jurisdicción pueden ser incompletas, no aplicar a un caso concreto o quedar desactualizadas por cambios normativos, interpretaciones o criterios de las autoridades posteriores a su fecha de consulta. **Cada organización que use SEVEN-G es la única responsable de identificar la normativa que le aplica, verificar su vigencia y certificar su propio cumplimiento regulatorio**, con el asesoramiento cualificado que corresponda. Esta metodología es una ayuda genérica y gratuita, compartida con la comunidad para que nadie tenga que empezar desde cero; cada persona u organización puede y debe adaptarla a su propio uso. No debe entenderse que sus partes jurídicamente sensibles hayan sido revisadas por una asesoría jurídica: esas revisiones, para cada empresa o sector, son responsabilidad última de la empresa, el consultor o la organización que la use. Aunque se procura mantenerla al día, alguna norma puede haber cambiado sin que se recoja aquí. En la máxima medida permitida por la ley, el autor no asume responsabilidad alguna por los efectos de su aplicación en ninguna organización ni por su aplicabilidad completa. La metodología no otorga certificación de ningún tipo. El autor no asume responsabilidad alguna por el uso que se haga de este contenido ni por las decisiones que se adopten con él. Los datos, cifras, compañías y casos de los ejemplos son ficticios o ilustrativos.

Por qué importa. La tercera línea no puede auditarlo todo cada año: el plan decide dónde se mira y dónde no. Sin un universo completo y una puntuación explícita, la cobertura depende de la disponibilidad del auditor y los sistemas de mayor riesgo pueden quedar años sin auditar. El plan hace visible a la comisión delegada qué queda sin cubrir y le obliga a decidir si amplía recursos o acepta ese riesgo. Es también el programa de auditoría interna que exige ISO/IEC 42001 (cláusula 9.2).

01

Instrucciones de uso

Aspecto	Indicación
Cuándo se usa	Se elabora una vez al año, antes del inicio del ejercicio, con los resultados de la revisión C5 del ejercicio anterior. Se actualiza cuando se incorpora al universo un sistema de prioridad Alta o se produce una auditoría no planificada (incidente S1, requerimiento de una autoridad).
Quién la rellena	Auditoría interna (responsable de auditoría de IA), con los datos de T02, T01 y T09 que facilita la oficina de IA.
Quién la verifica	La revisión de calidad de auditoría interna comprueba el universo y las puntuaciones antes de presentar el plan.
Quién decide o aprueba	La comisión delegada del consejo (38 §5.3; documento 30 §7.5). Si la auditoría de IA se integra en el plan de auditoría interna corporativa, se aprueba de forma conjunta o coordinada (38 §12.2).
Etapa del ciclo corporativo	Preparación tras C5; aprobación antes del inicio del ejercicio; seguimiento trimestral de su ejecución junto con la supervisión C4.
Herramienta	No tiene herramienta propia. El universo se extrae de T02 (inventario), T01 (registro de iniciativas) y T09 (proveedores); los hallazgos abiertos, de T08. Las fórmulas de la sección 4 permiten llevarla a una hoja de cálculo.
Documento de referencia	Documento 38 §4, §5 y §12; documento 21 §10.3 (muestra de *gates*); documento 43 §12 (auditoría del valor).
Lite frente a Enterprise	Los *gates* Enterprise se verifican todos; los *gates* Lite se auditan por muestra (21 §10.3: al menos el 10 % con un mínimo de tres, incluido al menos un G5). La intensidad es además un factor de la puntuación.

Reglas de cumplimentación:

- El universo incluye **todas** las unidades de 38 §5.1. Un sistema no inventariado no puede puntuarse: por eso la conciliación del inventario (32 §9) es una prueba recurrente de la auditoría del marco.
- La tabla de factores es **de referencia**. Si la compañía la ajusta, lo declara en la sección 4.1 y el ajuste lo aprueba la comisión delegada con el plan.
- La prioridad **Alta** se asigna también, sin mirar la puntuación, a todo sistema de alto riesgo en producción y a todo sistema con autonomía A3 y exposición directa.
- Se reserva entre el **10 % y el 20 %** de la capacidad para auditorías no planificadas.
- Si la capacidad no alcanza para cubrir los sistemas de prioridad Alta, la limitación se escribe en la sección 7 y la decide la comisión delegada.

02

Identificación

Campo	Contenido	Guía
Compañía y perímetro		Sociedades y áreas cubiertas por el plan.
Ejercicio		Año o periodo de doce meses.
Versión del plan		1.0 al aprobarse; 1.1, 1.2… en cada modificación aprobada.
Responsable de auditoría de IA		Nombre y cargo.
Fecha de corte del universo		DD-MM-AAAA. Fecha de extracción de T02, T01 y T09.
Relación con el plan de auditoría interna corporativa		Integrado · Coordinado.
Tabla de factores aplicada		De referencia (38 §5.2) · Ajustada (describir en 4.1).
Resultado de la última auditoría del marco		Conforme · Conforme con observaciones · No conforme, con su código AUD-AAAA-NNN.

03

Universo auditable

Se numera cada unidad de forma correlativa dentro del plan (U01, U02…). Una unidad es un sistema, una iniciativa, un proveedor, un proceso del marco o un tema transversal (38 §5.1).

Nº	Tipo de unidad	Código	Nombre	Fuente	Responsable	Estado o fase	Última auditoría (código y fecha)
U01	Sistema · Iniciativa · Proveedor · Proceso · Tema	SIA-AAAA-NNN · IA-AAAA-NNN · código de T09 · nombre del proceso		T02 · T01 · T09 · Documento · Informe de riesgos · T08			

Nº	Tipo de unidad	Código	Nombre	Fuente	Responsable	Estado o fase	Última auditoría (código y fecha)
U02							
U03							
(ejemplo ilustrativo) **U01**	Sistema	SIA-2026-014	Asistente de consultas de clientes	T02	Responsable de operación de IA del área de clientes	En producción	Nunca auditado
(ejemplo ilustrativo) **U02**	Proceso	—	Inventario y clasificación regulatoria	Documento 32	Oficina de IA	Operativo	AUD-2026-003 · 20-11-2026

Unidades que deben figurar como mínimo:

Unidad	Fuente	¿Incluidas todas? (Sí · No)	Si No, motivo
Cada sistema de IA en desarrollo, piloto o producción	T02		
Cada iniciativa con *gates* planificados en el ejercicio	T01		
Cada proveedor de IA con nivel N2 o N3	T09		
Procesos del marco: ciclo corporativo, gestión de cartera, inventario, riesgos, medición, no conformidades, políticas y alfabetización	Documentos 01, 14, 31, 32, 33, 37 y 40		
Temas transversales identificados por la segunda línea o por incidentes	Informes de riesgos; T08		

04

Puntuación de prioridad

4.1 Factores

Cada sistema del universo se puntúa de 1 a 3 en nueve factores (38 §5.2).

Nº	Factor	1	2	3
F1	Clasificación regulatoria	Riesgo mínimo o fuera de ámbito	Obligaciones de transparencia o excepción del artículo 6.3	Alto riesgo
F2	Intensidad	Lite	—	Enterprise
F3	Autonomía	A0	A1	A2 o A3
F4	Exposición	Interna	Empleados o clientes indirectamente	Clientes o personas externas directamente
F5	Riesgo residual principal	Bajo	Medio	Alto o Crítico
F6	Incidentes y no conformidades en 12 meses	Ninguno	S3–S4 o no conformidades menores	S1–S2 o no conformidades mayores o críticas
F7	Cambios relevantes desde la última auditoría	Ninguno	Cambios menores	Nuevo modelo, proveedor, finalidad, datos o autonomía
F8	Materialidad económica (coste recurrente o valor declarado)	Baja según umbral C2	Media	Alta
F9	Tiempo desde la última auditoría	Menos de 12 meses	12–24 meses	Más de 24 meses o nunca

Ajustes de la compañía a la tabla (si los hay) y motivo: _____.

4.2 Puntuación por unidad

Puntuación = F1 + F2 + … + F9 (de 9 a 27). **Prioridad**: **Alta** 21–27, o prioridad forzada · **Media** 15–20 · **Baja** 9–14.

Nº	F1	F2	F3	F4	F5	F6	F7	F8	F9	Puntuación	Prioridad forzada (Sí · No)	Prioridad	Cobertura exigida
U01												Alta · Media · Baja	
U03													
(ejemplo ilustrativo) **U01**	2	3	1	3	2	2	3	2	3	21	No	Alta	Continuidad en profundidad este ejercicio

En una hoja de cálculo, con los factores en las columnas B a J y la prioridad forzada en la columna L:

- Puntuación (K): `=SUMA(B2:J2)`
- Prioridad (M): `=SI(O(L2="Sí";K2>=21);"Alta";SI(K2>=15;"Media";"Baja"))`

Cobertura orientativa por prioridad (38 §5.2):

Prioridad	Cobertura
Alta	Auditoría de continuidad en profundidad al menos anual.
Media	Auditoría de continuidad al menos cada dos años; incluida en temáticas.
Baja	Por muestreo en temáticas o en la auditoría del marco; al menos cada tres años.

Los procesos del marco, los proveedores y los temas no se puntúan con esta tabla: los procesos se cubren con la auditoría anual del marco y los proveedores según su nivel N1–N3 (38 §4).

05

Plan de trabajos del ejercicio

5.1 Cobertura por bloque

Bloque (38 §5.3)	Regla de cobertura	Trabajos planificados	¿Cumple la regla? (Sí · No)
Auditorías de *gate* Enterprise	100 % de los *gates* Enterprise planificados en T01		
Auditorías de *gate* Lite	Muestra de 21 §10.3		
Auditorías de continuidad	Sistemas de prioridad Alta y los de Media que correspondan por rotación		
Auditoría del marco	Anual, incluida la declaración de aplicación (P61)		
Auditoría del valor	Al menos una vez al año antes de C5 (43 §12)		
Temáticas	Entre una y tres al año		
Proveedores	N3 al menos anual; N2 seleccionados		

Bloque (38 §5.3)	Regla de cobertura	Trabajos planificados	¿Cumple la regla? (Sí · No)
Seguimiento	100 % de las no conformidades mayores y críticas abiertas		
Reserva	10–20 % de la capacidad		

5.2 Trabajos

Código	Tipo	Unidad (Nº)	Objetivo y alcance	Criterios	Trimestre	Auditor principal	Expertos de apoyo	Horas estimada
AUD-AAAA-NNN	*Gate* · Continuidad · Marco · Temática · Proveedor · Valor · Seguimiento			Documento 21, 22, normas	1T · 2T · 3T · 4T			
***(ejemplo ilustrativo)* AUD-2027-004**	Continuidad	U01	Controles del asistente de consultas en los últimos doce meses: monitorización, supervisión humana, incidentes, valor y coste (38 §6.3)	R6.nn del documento 21; P24; P25	2T	Auditora principal de IA	Especialista en seguridad ofensiva	160

El código AUD-AAAA-NNN es el que propone 38 §9.1 y se mantiene en los papeles de trabajo (P59) y en el informe (P60). Las auditorías de *gate* reciben código cuando se solicita el *gate*.

06

Capacidad y recursos

Magnitud	Valor	Guía
Horas disponibles de auditores de IA en el ejercicio		Descontadas formación (perfil F6, documento 31 §6.2), vacaciones y otras tareas.

Magnitud	Valor	Guía
Horas de expertos externos contratadas		
Horas asignadas a trabajos (suma de 5.2)		
Reserva para trabajos no planificados		Horas y porcentaje sobre la capacidad (10–20 %).
Diferencia		Disponibles − asignadas − reserva. Si es negativa, hay limitación (sección 7).
Unidades de prioridad Alta sin cubrir		Número y lista.
Rotación de auditores principales		Sistemas Enterprise que el mismo auditor audita por más de [tres] ejercicios consecutivos (38 §3.1).

07

Aprobación del plan y limitaciones

Campo	Contenido	Guía
Limitaciones de cobertura		Unidades de prioridad Alta o Media que no se auditan en el plazo exigido y motivo.
Decisión de la comisión delegada sobre las limitaciones		Amplía recursos · Acepta el riesgo, con motivo.
Órgano que aprueba		Comisión delegada del consejo.
Fecha de aprobación		DD-MM-AAAA.
Referencia del acta		
Informe del plan al consejo		Fecha de la sesión en que se informa.

08

Seguimiento de la ejecución

Se presenta a la comisión delegada cada trimestre (38 §5.3). Las acciones vencidas se escalan según 30 §8.2 y figuran en este informe (38 §10).

Trimestre	Trabajos planificados	Terminados (informe final)	En curso	Aplazados (motivo)	No planificados añadidos	Grado de ejecución	Horas consumidas	Resulta No conforn
1T						%		
2T						%		
3T						%		
4T						%		

Grado de ejecución = trabajos terminados ÷ trabajos planificados hasta la fecha × 100. En una hoja de cálculo: `=SI(B2=0;"";C2/B2)`.

Modificación del plan	Fecha	Motivo	Trabajo afectado	Aprobada por
		Incidente S1 · Requerimiento · Cambio de prioridad · Capacidad		

09

Criterios de calidad

#	Comprobación	Estado
1	El universo incluye todos los sistemas de T02, las iniciativas con *gates* del ejercicio, los proveedores N2 y N3 y los procesos del marco.	Cumple · No cumple · No aplica · Pendiente
2	Cada sistema tiene los nueve factores puntuados con datos de la fecha de corte y la prioridad forzada aplicada cuando corresponde.	
3	Todos los sistemas de prioridad Alta tienen trabajo en el ejercicio o figuran como limitación aprobada.	

#	Comprobación	Estado
4	La auditoría del marco, con la declaración de aplicación, y la auditoría del valor están planificadas antes de C5.	
5	Se cumplen las reglas de cobertura de *gates* (100 % Enterprise; muestra Lite de 21 §10.3).	
6	Existe reserva de capacidad entre el 10 % y el 20 %.	
7	Ningún auditor principal tiene asignado un trabajo con incompatibilidad (30 §5, I-10 e I-11) ni supera la rotación recomendada.	
8	El plan está aprobado por la comisión delegada y su ejecución se informa cada trimestre.	

La pregunta D6.10 del documento 11 (auditoría del marco en los últimos 12 meses) se acredita con la ejecución de este plan.

10

Aprobación y verificación

Función	Rol en SEVEN-G	Nombre y cargo	Fecha	Firma o referencia
Elabora	Responsable de auditoría de IA (auditoría interna)			
Facilita los datos del universo	Oficina de IA			
Revisa la calidad	Revisión de calidad de auditoría interna			
Aprueba	Comisión delegada del consejo			

Separación de funciones: la oficina de IA aporta los datos, pero no decide qué se audita ni puntúa las unidades; ningún área que patrocine iniciativas aprueba el plan.

11

Control de versiones

Documento cumplimentado

Versión	Fecha	Autor	Cambios

Plantilla

Versión	Fecha	Cambios
0.1	19-09-2026	Primera versión. Aplica el universo auditable, los factores de prioridad, las reglas de cobertura y la aprobación y seguimiento de 38 §5, con fórmulas para hoja de cálculo.

Fuentes externas citadas

Enlaces a la fuente oficial o primaria, comprobados antes de publicar. Verifique siempre la versión vigente en la fecha de uso.

ISO/IEC 42001:2023 Tecnología de la información — Inteligencia artificial — Sistema de gestión · https://www.iso.org/standard/42001 · ISO/IEC (JTC 1/SC 42) · 18-12-2023